Connor Reid - 30347026

Tracing a Phishing Led account compromise in KC7

Summary

This project documents my completion of KC7 Cybers ‘A Rap Beef: An intro to Security investigations challenge’. Throughout this scenario I worked s a simulated analyst for OWL records, and used Kusto Query Language(KQL) to investigate a phishing led compromise of the artist Dwake. The content examined includes InboundNetworkEvents, PassiveDns, Email, Employees and AuthenticationEvents data, with the activity beginning with the suspicious IP address 18.66.52.227 and pivoting across each dataset to reconstruct the attack.

The evidence showed reconnaissance for Dwake’s contact information, including a password reset attempt using personal details that he had disclosed in song lyrics, the delivery of a phishing message linking to betterlyrics4u.com, a confirmed click from Dwake’s workstation, followed by a successful login from the attackers IP. queries ran post compromise revealed ten requests against Dwake’s account and a successful download named DwakesDirtySecrets.zip.

This investigation strengthened my ability to filter logs, correlate indicators, separate confirmed facts from interpretation and communicate a defensible timeline. It also showed the importance of MFA, the need for safer recovery processes, email filtering, monitoring and user awareness, and how combining all of these security features creates essential control against targeted social engineering attacks.

Introduction

Kc7 Cyber is a defensive security training platform that guides you through a simulated investigation and provides realistic log tables to query. I selected the Rap Beef Challenge because it combines log analysis with social engineering, open source intelligence and account security. These topics connect directly to the incident response and NIST cybersecurity framework 2.0 All investigation activity occurred inside KC7’s training environment using fictional data.

Problem and challenge

OWL Records faced a targeted phishing campaign against its artists. I had to determine how an adversary moved from research to account compromise and data theft. No single log explained the incident, so I followed the timestamps, usernames, IP addresses and domains across several datasets. The attackers searches suggest a personal grudge against Dwake, although the logs and extracted files do not prove the motive.

Project Goals and Objectives

- Use KQL to find suspicious events and reduce irrelevant results
- Correlate network, DNS, email, employee and authentication records into one timeline
- Explain how public information and phishing defeated account protections
- Recommend controls and collect accurate portfolio evidence

Methodology

I utilised KC7's KQL workspace and an incremental threat hunting process. Each confirmed result because the pivot for the next query. The relevant tables were Employees, InboundNetworkEvents, OutboundNetworkEvents, PassiveDNS, Email and AuthenticationEvents

Step 1 - Define the Scope and Starting Indicator

KC7 supplied 18.66.52.227 as the starting indicator. I limited the investigation to activity associated with this IP, beginning on the 10th of April 2024, and used KC7's KQL editor to search through the relevant tables. I defined the evidence needed to prove each stage, that is, reconnaissance, password recovery, delivery, interaction, authentication and the access the attackers had post compromise. Timestamp, src_ip, recipient, username, URL and result were the main linking fields. I began with InboundNetworkEvents search because it recorded the external IP's website requests

Step 2 - Examine the Attackers website activity

I filtered InboundNetworkEvents to the supplied IP and the April 10 window, then projected the timestamp, URL and status_code. This showed searches for Dwake, his OWL records email, and hostile comments regarding his music. The URLs established that the attacker had been researching Dwake and trying to find account information. Because the website activity also showed a password reset route and personal questions, I next narrowed the same table to the recovery attempt.

```
InboundNetworkEvents
| where timestamp between (datetime(2024-04-10) .. datetime(2024-04-11))
| where src_ip == "18.66.52.227"
| project timestamp, url, status_code
```

Step 3 - Identify the password recovery Attempt

By filtering through InboundNetworkEvents for the address 18.66.52.227, and the two answers found in Dwake's lyrics, Washington (Mothers maiden name), and Fluffy (his childhood pet). We get the result showing a security questions request at 13:02:47 with the status code 200. This did not itself prove that the account was accessed, it confirmed that the attacker submitted publicly discoverable recovery information linked to Dwakes account. I therefore searched PassiveDns to determine whether the source IP was associated with a domain used in the attack.

Step 4 - Resolve the IP to a Domain Used in the Attack

Here i queried PassiveDns for 18.66.52.227 and found that it was associated with betterlyrics4u.com. This connected the IP used in the recovery attempt to the suspicious domain. Because the domain could also appear in email and web traffic, i used betterlyrics4u as the next pivot and searched the email records for messages containing it.

Step 5 - Search email records and identify the Targets

In this step I filtered email for messages containing betterlyrics4u.com and found 13 campaign emails sent from ghostwritersananymous@protonmail.com and wemakebeatz@gmail.com. I then used a let expression and an in filter to match the recipients against OWL employees. Ten recipients matched employee records and were all Rappers, including lead rapper Dwake. Dwake's employee record identifies hid username as dwaudrey and his workstation IP as 10.10.0.5. His email came from ghostwritersanonymous@protonmail.com, and the subject head was 'need a ghost writer for your next hit' which received a CLEAN verdict. Because delivery did not prove that Dwake opened the link, We next searched through OutBoundNetworkEvents for evidence of interaction from his workstation

Step 6 - Confirm the interaction with the phishing site

I searched OutboundNetworkEvents for the exact phishing URL. Dwake's workstation, 10.10.0.5, opened it at 12:03:12 on the 15th of april. The click confirmed the interaction but not credential theft, so I then continued on to AuthenticationEvents

Step 7 - Confirm account takeover

I filtered AuthenticationEvents for username dwaudrey and the source IP 18.66.52.227. A successful login appeared at 13:03:12, one hour after the initial click. The username, source IP and timing connected the phishing activity to the account takeover

```
AuthenticationEvents
| where username == "dwaudrey"
| where src_ip == "18.66.52.227"
| project timestamp, username, src_ip, result
```

Step 8 - Trace Post compromise Activity

Finally, I extended the window to the first of May and filtered InboundNetworkEvents for Dwakes username dwaudrey, and the address 18.66.52.227. Ten account related requests matched the attacker IP and username. The wider period was necessary because the attacker remained active long after the initial login. The final request targeted the drafts folder with download=true and output=DwakesDirtSecrets.zip. Status code 200 confirmed a successful download, but the log however did not reveal the contents of the archive. I re-ran key queries, checked timestamps and saved the outputs before reporting the timeline.

Verified Attack Timeline

Date and Time	Stage	Verified Evidence
10th of April 13:02:47	Recovery	Security question request from 18.66.52.227 used Washington and Fluffy, returned 200
15th April 11:07:12	Delivery	CLEAN phishing email linked Dwake to betterlyrics4u.com
15 April 12:03:12	Click	Dwakes workstation 10.10.0.5 opened the phishing URL
15 April 13:03:12	Access	18.66.52.227 successfully logged in as dwaudrey
30th April 14:23:02	Download	Drafts request produced DwakesDirtySecrets.zip with HTTP 200, contents of file not visible

Results and Evidence

The investigation connected reconnaissance, a recovery attempt, phishing, a confirmed login and a later data download. Each finding was checked by matching the attacker IP, domain, account and timestamps across independent datasets.

- Recovery attempt. At 13:02:47Z on 10 April, InboundNetworkEvents recorded a request from 18.66.52.227 whose URL contained answer_1=Washington and answer_2=Fluffy, values disclosed in Dwake’s verse; the response was HTTP 200 (Figure 1).

- Email campaign and targets. Filtering for betterlyrics4u.com returned 13 messages from ghostwritersanonymous@protonmail.com and wemakebeatz@gmail.com. Employee correlation showed that rapper was the main targeted role and identified Dwake as lead rapper (Figures 2 and 3).
- Delivery and interaction. Dwake received '[EXTERNAL] RE: Need a ghostwriter for your next hit?' at 11:07:12Z. It was marked CLEAN and contained the phishing link; OutboundNetworkEvents then recorded his workstation 10.10.0.5 opening it at 12:03:12Z (Figure 4).
- Confirmed compromise. At 13:03:12Z, one hour after the click, AuthenticationEvents recorded a Successful Login for dwaudrey from 18.66.52.227 (Figure 5).
- Data download. The later query returned ten account-related requests. The final event at 14:23:02Z on 30 April requested Dwake's Drafts folder with download=true, output DwakesDirtySecrets.zip and HTTP 200. The log proves the download, not the archive contents (Figure 6).

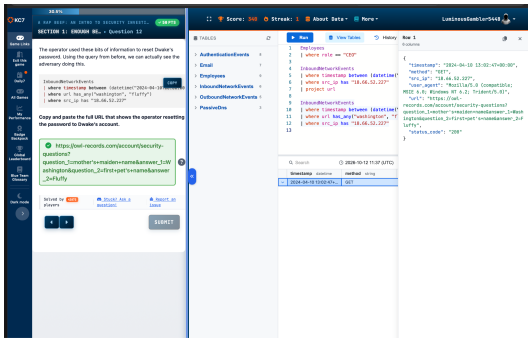


Figure 1 Recovery URL contains Washington and Fluffy at 13:02:47Z and returns HTTP 200.

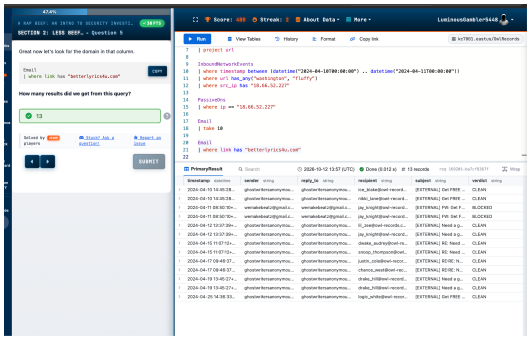


Figure 2 Email filtering returns 13 records and displays the two sender addresses.

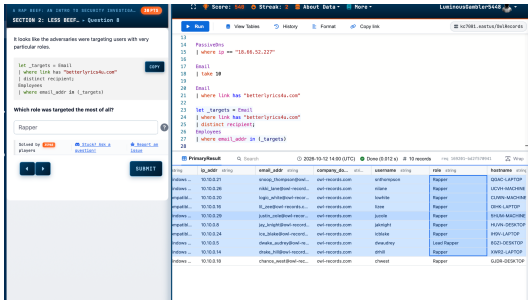


Figure 3 Employee correlation shows rappers as the main target and identifies Dwake as lead rapper.

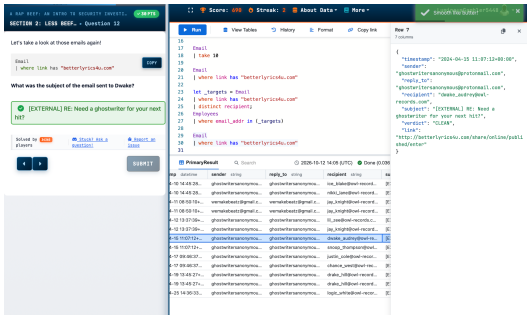


Figure 4 Dwake's email shows the sender, subject, CLEAN verdict and phishing link.

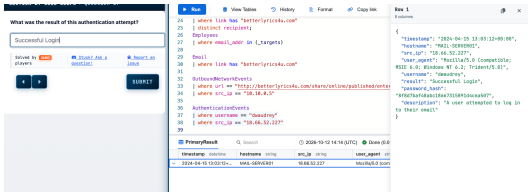


Figure 5 AuthenticationEvents records a Successful Login at 13:03:12Z from 18.66.52.227.

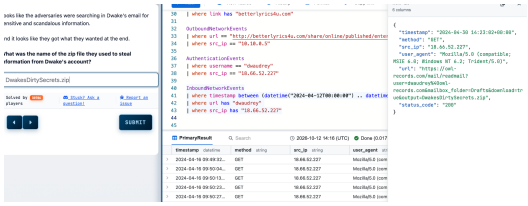


Figure 6 The final request shows Drafts, download=true, the ZIP output and HTTP 200 at 14:23:02Z.

Recommended Controls

These controls align with the NIST Cybersecurity Framework functions of Protect, Detect and Respond. To Protect accounts, OWL Records should replace personal security questions with identity verification through a trusted channel, which would have made the answers taken from Dwake's lyrics useless. Phishing-resistant MFA would have prevented the 13:03:12 login from succeeding on stolen credentials alone, and inspecting unfamiliar links, even when emails are marked CLEAN, would have acted where the email filter did not. Phishing and personal-information awareness training would reduce the chance of the click and of staff disclosing recovery answers publicly. To Detect attacks, monitoring should alert on logins from external IP addresses not previously seen for a user and on archive downloads from

folders such as Drafts, and should connect these with suspicious emails and link clicks. To Respond, the organisation should revoke active sessions, reset compromised credentials, block the attacker's IP address and domain, and review the other recipients.

Reflection

What I learned

I learned that an investigation depends on the correlation of several records. Network logs showed requests, passive DNS connected the IP to a domain, email logs showed the delivery, outbound traffic showed the click, and authentication logs proved the login. KQL filters such as where, between, has, project and distinct helped to reduce large datasets into only the relevant events. I also learned to separate factors from interpretation, the logs confirm the compromise and download, but they only suggest the attackers motive

Contribution to My Professional Growth

This exercise gave me a clearer picture of entry level security operations work. I practised forming a question, choosing a dataset, finding an indicator and pivoting to another log source. I became more confident reading structured events and explaining why records belong to the same incident. It also showed how public information, weak recovery questions and convincing phishing can replace the need for an advanced exploit. Writing the final timeline improved my ability to explain technical evidence in plain language and recommend controls that match the observed failure. The report gives me a practical investigation to include in my GitHub portfolio.

What I Would Do Differently

The main challenge was process, not technique. I collected screenshots after the investigation instead of during it, so I re-ran key queries to recover outputs and had no record of my confidence in each finding. The conclusions here held, but the evidence was harder to verify than it needed to be.

If I had to repeat this challenge I would keep an evidence log while working. I would record each question, query, timestamp, output and confidence level. I wold also save reusable KQL variables for the attack IP, domain and victim, then check each indicator across the given tables.

Portfolio & Challenge Link

https://github.com/Tigwobbly/ITECH1502-KC7-Cybersecurity-Portfolio